

iscte

INSTITUTO
UNIVERSITÁRIO
DE LISBOA

Segurança em Redes de Computadores

Licenciatura em Tecnologias Digitais e Segurança da Informação

Prof. João Pedro Pavia

Ano letivo 2025/2026

Índice de Conteúdos

1. Contexto e Motivação
2. Fundamentos Zero Trust
3. Componentes e Arquitetura
4. Implementação Prática
5. Casos de Uso e Ataques
6. Desafios e Futuro

O Modelo Perimetral Tradicional

- Baseado no princípio castle-and-moat: proteção forte nas fronteiras, confiança total no interior
- Assume que tudo dentro da rede corporativa é seguro e confiável
- Implementado com firewalls, VPNs, DMZs e IDS/IPS perimetrais
 - Firewall de perímetro como linha de defesa principal
 - VPN para acesso remoto — túnel cifrado mas com confiança implícita
 - Segmentação limitada — redes flat internas comuns
- Funcionou bem quando: utilizadores no escritório, dados em servidores locais, apps on-premise
- O mundo mudou — cloud, mobile, IoT, trabalho remoto dissolverem o perímetro

A Dissolução do Perímetro de Segurança

Cloud Computing

Dados e apps migram para AWS, Azure, GCP — fora do perímetro tradicional

BYOD & Mobile

Dispositivos pessoais acedem a recursos corporativos em qualquer lugar

Trabalho Remoto

Covid-19 acelerou: 70% das empresas com workforce distribuída globalmente

IoT & OT

Milhares de dispositivos conectados sem capacidade de agente de segurança

Third-Party Access

Fornecedores, parceiros e contractors acedem sistemas internos via VPN

SaaS Proliferation

Slack, Office 365, Salesforce — dados corporativos em múltiplos serviços

Falhas do Modelo Perimetral

- Movimento lateral: atacante dentro da rede move-se livremente sem restrições
 - SolarWinds 2020: meses dentro da rede sem detecção, acesso a dezenas de agências
 - Target 2013: comprometimento via fornecedor HVAC, lateral para sistemas POS
- Insider threats: utilizador legítimo com má intenção tem acesso amplo e irrestrito
 - Edward Snowden: insider com credenciais válidas exfiltrou TB de dados da NSA
- Credential theft: roubo de credenciais VPN = acesso total e imediato à rede interna
- Flat networks: sem microsegmentação, 1 host comprometido $\approx$ rede comprometida
- Cloud e SaaS: tráfego nunca passa pelo firewall perimetral — invisível para os controles

O Custo dos Incidentes de Segurança

\$4.45M

Custo médio de um
data breach (2023)

277 dias

Tempo médio para
identificar e conter

82%

Breaches com
elemento humano

61%

Ataques envolvem
credenciais roubadas

Fonte: IBM Cost of a Data Breach Report 2023 · Verizon DBIR 2023

A Origem do Conceito Zero Trust

- 2003 — Jericho Forum: publica princípios de de-perimeterisation
 - Reconhece que o perímetro está a dissolver-se — propõe design seguro por defeito
- 2010 — John Kindervag (Forrester): cunha o termo Zero Trust
 - Whitepaper: 'No More Chewy Centers: Introducing The Zero Trust Model'
 - Princípio: eliminar confiança implícita baseada na localização de rede
- 2011-2014 — Google implementa BeyondCorp internamente após Operation Aurora (APT chinês)
 - Publica 6 papers BeyondCorp — blueprint aberto para a indústria
- 2020 — NIST SP 800-207: define formalmente Zero Trust Architecture
- 2021 — Executive Order EO 14028 (Biden): ZTA mandatório no governo federal dos EUA

Os 3 Princípios Core do Zero Trust

- 1. VERIFY EXPLICITLY — Autenticar e autorizar sempre, em todos os contextos
 - Baseado em identidade, localização, dispositivo, serviço, classificação de dados e anomalias
 - Nunca assumir confiança com base em rede, IP ou localização física
- 2. USE LEAST PRIVILEGE ACCESS — Acesso mínimo necessário, just-in-time
 - Limitar acesso com políticas adaptativas baseadas em risco calculado em tempo real
 - Proteger dados limitando o blast radius em caso de comprometimento
- 3. ASSUME BREACH — Minimizar raio de explosão, segmentar, encriptar tudo
 - Comportar-se como se o atacante já estivesse na rede — porque provavelmente está
 - End-to-end encryption, analytics para detecção, melhoria contínua de defesas

Zero Trust vs Modelo Perimetral

Modelo Perimetral

- Confia em utilizadores dentro da rede
- Verifica na entrada, confia depois
- Acesso amplo após autenticação VPN
- Difícil auditar internamente
- Movimento lateral facilitado
- Perímetro como defesa principal
- Segmentação de rede limitada
- Reagir após deteção de breach

Zero Trust Architecture

- Never trust, always verify — em qualquer local
- Autenticação e autorização contínuas por sessão
- Acesso granular e mínimo por recurso
- Logging e analytics de todo o tráfego
- Microsegmentação impede movimento lateral
- Identidade como novo perímetro
- Micro-perímetros por recurso/aplicação
- Assume breach — segmentação limita impacto

A Identidade como Novo Perímetro

- No ZT, a identidade substitui a localização de rede como base de confiança
- Identidade engloba: utilizadores humanos, serviços, aplicações, dispositivos e workloads
- Identity Provider (IdP): fonte de verdade para todas as identidades
 - Exemplos: Microsoft Entra ID, Okta, Ping Identity, Keycloak (open-source)
- Multi-Factor Authentication (MFA) é OBRIGATÓRIO em qualquer ZTA real
 - FIDO2/WebAuthn: autenticação forte resistente a phishing — padrão ouro atual
 - TOTP/HOTP (Authenticator apps): amplamente suportado mas phishable via AiTM
- Conditional Access: autorização dinâmica baseada em múltiplos sinais de risco
- Single Sign-On (SSO) + Federation (SAML 2.0, OIDC, OAuth 2.0) para experiência coesa

Os 7 Pilares do Zero Trust (CISA/DoD)

- 1. Identity — IAM, MFA forte, PAM, JIT access, FIDO2/Passkeys
- 2. Devices — MDM/UEM, compliance check, EDR/XDR, device attestation (TPM)
- 3. Networks — Microsegmentação, ZTNA, SDP, encrypted East-West traffic
- 4. Applications — API Gateway, OAuth/OIDC, WAF, zero-trust app access
- 5. Data — Classificação, DLP, CASB, encryption at-rest/transit, DRM
- 6. Visibility & Analytics — SIEM, UEBA, XDR, Threat Intel, full packet capture
- 7. Automation & Orchestration — SOAR, Policy as Code, CI/CD security

Confiança Adaptativa e Avaliação Contínua

- ZT não é binário (confiar/não confiar) — usa confiança como score contínuo
- Trust Score calculado em tempo real com base em múltiplos factores:
 - Identidade verificada com MFA forte → score aumenta
 - Dispositivo gerido, compliant, sem malware → score aumenta
 - Localização incomum ou viagem impossível → score diminui
 - Comportamento anómalo (acesso a dados incomuns) → score diminui
 - Credencial comprometida conhecida → acesso bloqueado imediatamente
- Re-autenticação exigida quando o score desce abaixo do threshold definido na política
- UEBA (User and Entity Behavior Analytics) integrado no motor de políticas

Modelo de Referência NIST SP 800-207

- Publicado pelo NIST em Agosto 2020 — referência normativa global para ZTA
- Componentes principais do modelo NIST:
 - PEP (Policy Enforcement Point): intercepta TODOS os pedidos de acesso a recursos
 - PE (Policy Engine): cérebro do sistema — toma as decisões de acesso
 - PA (Policy Administrator): traduz decisão do PE em tokens/credenciais de acesso
- Fontes de dados para o Policy Engine:
 - CDM System (Continuous Diagnostic and Mitigation): postura de dispositivos
 - Threat Intelligence: feeds de IOCs, CVEs, IP reputation, domínios maliciosos
 - SIEM/logs: contexto comportamental histórico do utilizador e entidade
 - PKI: validação de certificados e identidades de workloads

PEP, PE e PA — Em Detalhe

- Policy Enforcement Point (PEP):
 - Gateway de acesso — stateless, executa decisões sem as tomar
 - Implementações: API Gateway, Reverse Proxy, NAC, CASB, ZTNA broker
- Policy Engine (PE):
 - Avalia pedido contra policies + dados de fontes externas em tempo real
 - Outputs: GRANT, DENY, ou condicionais (step-up MFA, read-only, sessão limitada)
 - Algoritmos: RBAC, ABAC, ou combinação adaptativa com ML
- Policy Administrator (PA):
 - Interface entre PE e PEP — gera tokens/certs de curta duração
 - Analogia: PE = juiz, PA = oficial de justiça, PEP = porteiro

Microsegmentação de Rede

- Divisão da rede em micro-segmentos com políticas de acesso individuais
- Impede o movimento lateral — principal vector após comprometimento inicial
- Abordagens de implementação:
 - VLAN/VXLAN: segmentação Layer 2/3 — granularidade limitada
 - Software-Defined Networking (SDN): políticas programáticas centralizadas
 - Service Mesh (Istio, Linkerd): microsegmentação para microserviços/containers
 - Host-based firewall com políticas centralizadas: Illumio, Guardicore/Akamai
- Identity-based microsegmentation: política baseada em identidade, não em IP
 - IPs mudam (DHCP, cloud, containers) — identidade é mais estável e auditável
- Software-Defined Perimeter (SDP): cada recurso com micro-perímetro próprio

SASE e ZTNA — Substituindo a VPN

- SASE (Secure Access Service Edge): convergência de WAN e segurança como serviço cloud
- SASE = SD-WAN + SSE (Security Service Edge)
- Componentes SSE:
 - CASB: visibilidade e controlo de apps SaaS (Shadow IT, DLP)
 - SWG (Secure Web Gateway): filtragem web, TLS inspection, URL filtering
 - ZTNA: substitui VPN — acesso por identidade a apps específicas
 - FWaaS: firewall de nova geração em cloud sem hardware
- ZTNA vs. VPN:
 - VPN: utilizador → rede corporativa → acesso a qualquer recurso interno
 - ZTNA: utilizador → apenas a app X autorizada — rede interna invisível
- Vendedores SASE: Zscaler, Palo Alto Prisma Access, Netskope, Cloudflare One

NIST SP 800-207 — Abordagens de Deployment

- 3 abordagens de deployment identificadas no NIST SP 800-207:
- 1. Identity-Based ZTA:
 - Confiança centrada em credenciais de identidade e device health attestation
 - IAM robusto com MFA + PAM + device compliance como controles principais
- 2. Micro-Segmentation ZTA:
 - Segmentação fina da rede com gateways individuais por recurso
 - Granularidade até ao nível de workload/aplicação individual
- 3. Network Infrastructure ZTA:
 - SDN com plano de controlo separado — SDP/overlay network
 - Software-Defined Perimeter com Single Packet Authorization (SPA)
- Recomendação: combinar as 3 abordagens — são complementares, não mutuamente exclusivas

CISA Zero Trust Maturity Model v2.0

- 4 níveis de maturidade avaliados em cada um dos 7 pilares ZT:
- Traditional: gestão manual, permissões estáticas, sem automação nem telemetria
 - Exemplo: grupos AD estáticos, VPN sem MFA, sem MDM, firewall com regras manuais
- Initial: início de automação, algumas dependências cross-pilar, telemetria básica
 - Exemplo: MFA deployado, MDM implementado, SIEM com logs básicos
- Advanced: automação distribuída, integração entre pilares, políticas dinâmicas
 - Exemplo: Conditional Access, microsegmentação, UEBA integrado, CASB activo
- Optimal: operações dinâmicas, just-in-time, IA/ML na tomada de decisões
 - Exemplo: JIT access, passwordless, ML anomaly detection, policy as code

Roadmap de Implementação ZTA

- Fase 1 — Visualizar (Assess & Inventory):
 - Inventariar assets: utilizadores, dispositivos, apps, dados, serviços, dependências
 - Mapear fluxos de dados e identificar protect surfaces (dados/assets críticos)
- Fase 2 — Definir Políticas (Policy Design):
 - Modelo Kipling: Who, What, When, Where, Why, How para cada recurso
 - Implementar RBAC/ABAC e documentar least-privilege baseline
- Fase 3 — Implementar Controlos Técnicos:
 - MFA universal, MDM/UEM, PAM, microsegmentação por prioridade de risco
 - Deploy ZTNA substituindo VPN legacy, integrar SIEM/SOAR
- Fase 4 — Monitorizar e Melhorar:
 - Telemetria contínua, threat hunting, ajuste de políticas baseado em dados reais

Caso de Estudo: Google BeyondCorp

- Contexto: Operation Aurora (2010) comprometeu Google — resposta foi re-arquiteturar segurança
- Publicado em 6 papers académicos (2014-2018) — blueprint aberto para a indústria
- Princípios BeyondCorp implementados:
 - Acesso a serviços não depende da rede — VPN eliminada para 100.000+ funcionários
 - Acesso baseado em: identidade do utilizador + estado do dispositivo + contexto
 - Todo o acesso é autenticado, autorizado e cifrado end-to-end
- Componentes chave:
 - Device inventory service: base de dados de todos os dispositivos e estado compliance
 - Access proxy: front-end para todos os serviços (equivalente ao PEP NIST)
 - Trust inferrer: calcula trust tier do dispositivo baseado em posture score
- Inspirou o produto comercial Google BeyondCorp Enterprise (Cloud IAP)

Cenário: Ransomware com e sem Zero Trust

- Ataque: Email de phishing → macro executada → Cobalt Strike beacon instalado
- SEM Zero Trust (resultado típico):
 - Atacante obtém hash NTLM → pass-the-hash → movimento lateral livre na rede
 - Acede a shares de rede → encripta ficheiros de toda a organização
 - Double extortion: exfiltração antes de encriptação (tempo médio: semanas)
- COM Zero Trust:
 - Microsegmentação: máquina comprometida isolada — sem acesso lateral
 - Least privilege: utilizador sem acesso a shares de outros departamentos
 - UEBA: comportamento anómalo (encriptação em massa) detetado → sessão suspensa
 - Blast radius: apenas 1 máquina afectada vs. toda a organização

Ataques: O que o ZT Mitiga vs O que Não Elimina

ZT Mitiga Eficazmente

- Credential stuffing / password spray — MFA bloqueia
- Pass-the-hash / Pass-the-ticket — tokens de curta duração
- Lateral movement — microsegmentação + least-privilege
- Insider threat — UEBA + monitorização contínua
- Supply chain — acesso limitado de terceiros
- VPN exploitation — ZTNA não expõe a rede
- Kerberoasting — PAM gere service accounts

ZT Não Elimina Completamente

- Zero-day exploits no browser/OS — EDR/XDR necessário
- Social engineering / deepfakes — awareness training
- Physical access a dispositivos — MDM + disk encryption
- DDoS — mitigação separada (CDN, scrubbing centers)
- AiTM phishing — captura token OAuth mesmo com MFA
- Quantum computing — migração pós-quântica futura
- AI-powered attacks — defesas adaptativas necessárias

Caso Real: SolarWinds SUNBURST (2020)

- Um dos maiores ataques de supply chain da história — 18.000 organizações afectadas
- Vector: comprometimento do pipeline de build da SolarWinds → DLL maliciosa em updates legítimos
- Impacto: FireEye, Microsoft, CISA, DoJ, Treasury, DHS comprometidos durante meses
- Como ZT teria ajudado:
 - Microsegmentação limitaria acesso do servidor Orion a sistemas críticos
 - Least-privilege: service accounts SolarWinds sem acesso ao AD Domain
 - UEBA: padrão de tráfego anómalo do beacon C2 detetado por ML
 - TLS inspection: comunicação C2 sobre HTTPS detetada como suspeita
- Limitações do ZT neste caso:
 - Supply chain: ZT não previne instalação de software comprometido
 - Assinatura digital válida: difícil detetar a priori sem SBOM e binary analysis

Caso Real: Colonial Pipeline (2021)

- Maior ataque ransomware a infraestrutura crítica dos EUA
- Vector: credencial VPN roubada (sem MFA) — conta de acesso remoto legacy inactiva
 - A credencial estava num lote de dados vazados na dark web
- Ransomware DarkSide: encriptou sistemas IT; empresa desligou OT por precaução
- Impacto: \$4.4M em resgate, escassez de combustível em 5 estados, 6 dias de paragem
- Lições Zero Trust:
 - MFA obrigatório: credencial roubada inútil sem segundo factor de autenticação
 - Segmentação IT/OT: sistemas operacionais isolados dos sistemas IT
 - Monitorização contínua: detecção precoce de acesso em horário e origem incomuns
 - ZTNA vs. VPN: sem VPN não há acesso amplo à rede após roubo de credencial
- Resultado: TSA emitiu directivas — MFA e ZT tornaram-se requisitos para pipelines

Zero Trust para Workloads Cloud-Native

- Workload Identity: cada microserviço tem identidade própria (não baseada em IP)
- SPIFFE/SPIRE: framework de identidade para workloads em ambientes heterogêneos
 - SVID: certificado X.509 de curta duração gerado e rotado automaticamente
- Kubernetes Network Policies — ZT nativo em K8s:
 - Default deny: bloquear todo o tráfego inter-pod por defeito (whitelist model)
 - Allow only: permitir apenas fluxos explicitamente necessários e documentados
- OPA (Open Policy Agent): policy engine para clouds nativas — Policy as Code
 - Rego language: políticas como código versionável (Git) e testável em CI/CD
- Secrets Management: HashiCorp Vault, AWS Secrets Manager, Azure Key Vault
 - Segredos dinâmicos: credenciais geradas on-demand, expiram automaticamente

Desafios da Implementação Zero Trust

- Complexidade: ZT não é um produto — é uma transformação estratégica multi-ano
 - Requer mudanças organizacionais, culturais e técnicas em simultâneo
- Custo: investimento significativo em tooling, integração e expertise especializado
 - Gartner: organizações gastam \$2-5M em iniciativas ZT de 3-5 anos
- Legacy systems: aplicações antigas sem suporte a autenticação moderna
 - Mainframes, SCADA/ICS, aplicações sem suporte a OIDC/SAML — necessitam wrappers
- User experience: fricção adicional com MFA e acesso granular — resistência cultural
- Visibilidade total: ZT exige logging de tudo — custo de storage e SIEM elevado
- Vendor lock-in: muitas soluções ZT são proprietárias e difíceis de migrar
- ZT washing: marketing abusa do termo — muitos produtos re-branded sem substância real

Regulação e Compliance Relacionados com ZT

- NIS2 Directive (EU, 2023): segurança de redes para entidades essenciais e importantes
 - Exige: gestão de risco, controlos de acesso, segmentação, monitorização, reporting
- DORA (Digital Operational Resilience Act): setor financeiro EU — Janeiro 2025
 - Resiliência de TIC, gestão de terceiros (TPRM), testes de penetração obrigatórios
- GDPR: ZT contribui para privacidade by design via minimização de acesso a dados pessoais
- EO 14028 (EUA, 2021): Federal ZT Strategy — agências federais em migração para ZTA
 - CISA ZT Maturity Model como guia oficial de implementação governamental
- SOC 2 / ISO 27001: ZT alinha com controlos de acesso (AC) e monitorização (AU)
- PCI DSS v4.0: microsegmentação e MFA como controlos obrigatórios para dados de cartões

○ Futuro do Zero Trust

- Quantum-Safe ZTA: migração para algoritmos pós-quânticos (NIST PQC 2024)
 - ML-KEM (Kyber), ML-DSA (Dilithium): aprovados pelo NIST para PKI pós-quântica
 - Hybrid certificates: TLS com algoritmos clássicos + pós-quânticos em paralelo
- Decentralized Identity (DID): W3C standard — identidade soberana sem IdP centralizado
- Zero Trust for AI Systems: modelos de IA como 'identidades' com políticas de acesso
 - AI agents precisam de acesso controlado a APIs, dados e ferramentas — ZT for AI
- Passwordless Everything: FIDO2/Passkeys eliminando passwords completamente
 - Apple, Google, Microsoft: passkeys como default — fim do credential stuffing/phishing
- 5G Network Slicing + ZT: segmentação nativa em redes 5G com identidade por slice
- ZT como regulação obrigatória: expectativa de mandato em sectores críticos EU/US até 2027

Métricas e KPIs para Zero Trust

- Como medir o sucesso de uma implementação Zero Trust?
- Métricas de Identidade:
 - % utilizadores com MFA forte activo (target: 100% para acessos a dados críticos)
 - Contas com privilégios excessivos detectadas em access reviews periódicos
- Métricas de Dispositivos:
 - % devices geridos e compliant (target: 100% para acesso a dados classificados)
 - Tempo médio para remediar dispositivo não-compliant (target: < 4 horas)
- Métricas de Rede e Detecção:
 - Número de micro-segmentos implementados vs. roadmap definido
 - MTTD (Mean Time to Detect) — redução percentual após implementação de ZT
 - Movimentos laterais bem-sucedidos detectados (target: zero tolerância)

Exercício Prático: Desenho de uma ZTA

- Cenário: PME com 50 funcionários, regime híbrido, Microsoft 365, ERP SAP on-premise e aplicação web interna. Sofreram incidente de phishing no último ano.
- Tarefas:
 - 1. Identificar os protect surfaces — que dados/sistemas são mais críticos?
 - 2. Mapear utilizadores e tipos de acesso necessários (Modelo Kipling)
 - 3. Propor controlos ZT para: Identity, Devices, Networks, Applications
 - 4. Definir política de Conditional Access para o cenário de phishing anterior
 - 5. Justificar escolhas de tecnologias open-source vs. comerciais
- Referências para consulta:
 - NIST SP 800-207 — nist.gov/publications
 - CISA ZT Maturity Model v2.0 — cisa.gov/zero-trust-maturity-model

Resumo: O que implementar em cada Pilar ZT

- Identity: MFA universal · SSO/Federation · PAM · JIT access · FIDO2/Passkeys
- Devices: MDM/UEM · Compliance check · EDR/XDR · Device attestation (TPM 2.0)
- Networks: Microsegmentação · ZTNA · SDP · Encrypted East-West · DNS security
- Applications: API Gateway · OAuth/OIDC · WAF · DAST/SAST · Zero-trust app access
- Data: Classificação · DLP · CASB · Encryption at-rest/transit · DRM/IRM
- Visibility: SIEM · UEBA · XDR · Threat Intel (STIX/TAXII) · Packet capture
- Automation: SOAR · Policy as Code · CI/CD security gates · IaC scanning
- Princípio fundamental: Zero Trust não é um destino — é uma jornada contínua de melhoria
 - Começar pelos protect surfaces mais críticos e expandir iterativamente
 - Medir continuamente com KPIs e ajustar políticas com base em dados reais

Referências Adicionais acerca dos Temas Abordados

- NIST SP 800-207 (2020) — Zero Trust Architecture — nist.gov
- CISA Zero Trust Maturity Model v2.0 (2023) — cisa.gov
- DoD Zero Trust Strategy (2022) — defense.gov
- 'Zero Trust Networks' — Gilman & Barth, O'Reilly 2017
- 'Zero Trust Security' — Jason Garbis & Jerry Chapman, Apress 2021
- CISA Zero Trust Learning Resources — cisa.gov/zt-resources
- Microsoft Learn: Zero Trust modules — learn.microsoft.com
- SANS SEC530: Defensible Security Architecture and Engineering



iscte

INSTITUTO
UNIVERSITÁRIO
DE LISBOA